



RASTRO

Trazabilidad verificable de envíos

Sergio Montoya · Nicolás Torres · Oscar Rincón
Cloud Computing (ISD38) · Grupo 30112

1 · Portada · Sergio · ≈ 15 s

Sergio: Buenos días, profesor. Somos Sergio Montoya, Nicolás Torres y Oscar Rincón, del grupo 30112. Vamos a sustentar Rastro, un sistema de trazabilidad de envíos que construimos y desplegamos en AWS, siguiendo los siete bloques que usted pidió.

INDICACIÓN Diez segundos. Mirar al jurado, no a la pantalla.

BLOQUE 1

Presentación del sistema

- 2 Contexto y necesidad
- 3 Qué es el sistema
- 4 Por qué importa



Rastro

Bloque 1

Bloque 1 · Presentación del sistema

Portadilla: se pasa sin detenerse.

Contexto y necesidad

Organización. Empresa de mensajería urbana de pequeño tamaño en Bogotá, con flota reducida y clientes corporativos.

El estado de un envío vive hoy en cuatro sitios a la vez: la memoria del mensajero, un chat, una hoja de cálculo y la llamada del despachador.

No existe un registro que diga quién cambió el estado, cuándo y con qué respaldo.



2 · Contexto y necesidad · Sergio · ≈ 30 s

Sergio: El caso es una empresa pequeña de mensajería urbana en Bogotá, con pocos vehículos y clientes corporativos. Hoy el estado de un envío está repartido en cuatro sitios: la memoria del mensajero, un chat, una hoja de cálculo y lo que el despachador averigua por teléfono. Información hay; lo que no hay es un registro que diga quién cambió el estado, cuándo y con qué respaldo.

INDICACIÓN La última frase es el problema. No adelantar la solución.

Qué es el sistema

Rastro traslada ese registro a un sistema que obliga a que cada cambio quede **atribuido, fechado y validado** contra un conjunto de transiciones permitidas.

Desplegado en AWS: ocho funciones, tres tablas, almacén cifrado, registro de actividad.

Infraestructura compartida entre varias empresas, con datos aislados.

Cuenta 484948252891 · us-east-1



3 · Qué es el sistema · Sergio · ≈ 30 s

Sergio: Rastro lleva ese registro a un sistema donde cada cambio queda atribuido a una persona, fechado y validado: un envío no puede pasar de creado a entregado sin recorrer los pasos intermedios. Está desplegado en AWS, en us-east-1: una puerta de enlace, ocho funciones Lambda, tres tablas, un almacén de evidencias cifrado y el registro de actividad. Varias empresas comparten la infraestructura, pero cada una solo ve sus datos.

INDICACIÓN Señalar la figura de arriba abajo, sin recorrer caja por caja.

Por qué importa

Consecuencia hoy	Efecto
Las reclamaciones se resuelven por acuerdo, no por consulta	Se asume el costo sin poder demostrar lo contrario
El despachador reconstruye información por teléfono	Tiempo operativo en una tarea sin valor
No se puede acreditar que el procedimiento se cumplió	Se pierden clientes que lo exigen

Sobre la evidencia del problema: procede de la experiencia laboral del equipo, declarada con sus limitaciones en el documento. Es observación no sistemática y así está escrito.



4 · Por qué importa · Sergio · ≈ 30 s

Sergio: Esto importa por tres razones. Sin ese registro, las reclamaciones se resuelven por acuerdo y la empresa asume el costo sin poder demostrar lo contrario; el despachador pierde tiempo reconstruyendo información por teléfono, y no se puede acreditar ante un cliente que el procedimiento se cumplió. Una aclaración: esta evidencia viene de la experiencia laboral del equipo. Es observación no sistemática, y así está declarada en el documento.

INDICACIÓN Decir la aclaración de frente: si el jurado la detecta primero, parece que la escondíamos.

BLOQUE 2

Planificación

- 5 Objetivos
- 6 Alcance y exclusiones
- 7 Responsables, recursos y cronograma
- 8 Actividades realizadas



Rastro

Bloque 2

Bloque 2 · Planificación

Portadilla: se pasa sin detenerse.

Objetivos

General. Desarrollar un sistema que registre de forma **verificable** el ciclo de vida de cada envío, con control de acceso por rol, aislamiento entre organizaciones y evidencia de entrega cifrada.

Específicos

1. Caracterizar el proceso actual y sus puntos de pérdida de información
2. Diseñar arquitectura y modelo de datos según las restricciones del entorno
3. Construir y desplegar sobre servicios gestionados
4. Verificar mediante pruebas que los controles funcionan

La palabra que carga el peso es *verificable*: no que funcione, sino que cualquiera pueda comprobarlo.



5 · Objetivos · Sergio · ≈ 30 s

Sergio: El objetivo general fue desarrollar un sistema que registre de forma verificable el ciclo de vida de cada envío, con control de acceso por rol, aislamiento entre organizaciones y evidencia cifrada. Lo dividimos en cuatro objetivos, uno por fase: caracterizar el proceso, diseñar, construir y desplegar, y verificar con pruebas. La palabra clave es «verificable»: no basta con que funcione, cualquiera tiene que poder comprobarlo.

INDICACIÓN La idea de «verificable» se retoma en el bloque de evidencias.

Alcance y exclusiones

Dentro	Fuera
Ciclo de vida del envío con identificador no predecible	Registro autónomo de organizaciones
Consulta pública sin autenticación	Rastreo por posición continua del vehículo
Evidencia de entrega cifrada	Optimización de rutas
Aislamiento entre organizaciones	Aplicación móvil nativa
Autorización por rol con registro del intento	Notificaciones automáticas
Bitácora encadenada y despliegue reproducible	

Condicionado y no logrado: retención inmutable del almacén. El entorno no la permitió y se declara.



6 · Alcance y exclusiones · Sergio · ≈ 35 s

Sergio: Dentro del alcance quedó el ciclo de vida con un identificador que no se puede adivinar, la consulta pública sin cuenta, la evidencia cifrada, el aislamiento entre empresas, la autorización por rol y la bitácora encadenada. Dejamos fuera, entre otras cosas, el rastreo continuo del vehículo: no solo por costo, sino porque implicaría vigilar al trabajador. Y declaramos lo que no logramos: la retención inmutable del almacén, que el laboratorio no permitió.

SI PREGUNTAN ¿Por qué no rastreo continuo? Además del costo, registrar la posición todo el tiempo documenta a la persona y no al envío. Por eso la ubicación solo se captura al registrar cada evento.

Responsables, recursos y cronograma

Fase	Semanas	Responsable	Estado
Diagnóstico y validación de supuestos	1–2	Oscar Rincón	Cerrada
Diseño	3–4	Sergio Montoya	Cerrada
Construcción y despliegue	5–9	Nicolás Torres · Sergio Montoya	Cerrada
Verificación y cierre	10–12	Oscar Rincón	En curso

Recursos. Presupuesto de 50 dólares por cuenta. Único cargo fijo: la llave de cifrado. Se excluyen deliberadamente los recursos que facturan entre sesiones.



7 · Responsables, recursos y cronograma · Sergio · ≈ 35 s

Sergio: Trabajamos doce semanas en cuatro fases. Oscar hizo el diagnóstico y cierra la verificación; yo me encargué del diseño, y la construcción y el despliegue los hicimos Nicolás y yo. Las tres primeras fases están cerradas; la última cierra con esta entrega. El recurso crítico era el presupuesto, 50 dólares por cuenta: el único cargo fijo es la llave de cifrado, y excluimos a propósito todo lo que factura entre sesiones.

SI PREGUNTAN El riesgo del presupuesto no es el volumen de uso, que en pruebas es marginal, sino dejar encendido un recurso que factura sin usarse.

Actividades realizadas

- Pruebas preliminares sobre permisos y exposición del entorno
- Once decisiones de arquitectura registradas antes de implementarlas
- Ocho servicios, dos interfaces web y capa común de control
- Secuencia de despliegue idempotente con verificación posterior
- 238 pruebas automatizadas escritas junto con el código
- Despliegue y verificación completa el 26 de septiembre



8 · Actividades realizadas · Sergio · ≈ 20 s

Sergio: En resumen: pruebas preliminares de permisos antes de construir, once decisiones de arquitectura registradas antes de implementarlas, ocho servicios con dos interfaces y una capa común de control, un despliegue que se puede repetir sin duplicar nada, 238 pruebas automatizadas y el despliegue verificado el 26 de septiembre.

INDICACIÓN Es inventario: pasar rápido.

BLOQUE 3

Metodología

- 9 Enfoque y regla que lo sostuvo
- 10 Técnicas empleadas y por qué



Rastro

Bloque 3

Bloque 3 · Metodología

Portadilla: se pasa sin detenerse.

Enfoque y regla que lo sostuvo

Enfoque **iterativo e incremental** en cuatro fases, una por objetivo específico.

Regla que gobernó todo el trabajo:

**Ningún requisito se dio por cumplido
antes de tener su prueba automatizada.**

Eso convirtió la verificación en parte de la construcción y no en una fase posterior. Por eso la suite creció al mismo ritmo que el sistema.



9 · Enfoque y regla que lo sostuvo · Sergio · ≈ 30 s

Sergio: Seguimos un enfoque iterativo e incremental, una fase por objetivo. No adoptamos un marco ágil completo, porque tres personas con dedicación parcial no sostienen sus ceremonias. Lo que sí sostuvimos fue una regla: ningún requisito se dio por cumplido sin su prueba automatizada. Así la verificación fue parte de la construcción, y por eso la cobertura no se cayó cuando el alcance creció. Nicolás explica las técnicas.

Técnicas empleadas y por qué

Técnica	Para qué	Por qué esa
Registro de decisiones de arquitectura	Documentar antes de implementar	Evita que el código y el documento se contradigan
Prueba mínima de capacidad	Validar supuestos del entorno	Comprobar antes de construir sobre una capacidad
Pruebas unitarias	Reglas independientes de la infraestructura	Rápidas y sin credenciales
Pruebas de extremo a extremo	Requisitos sobre la pila completa	Organizadas por requisito, no por módulo
Verificación posterior al despliegue	Que cada componente exista y responda	Código de salida automatizable
Auditoría independiente	Que los controles funcionen	Quien despliega no debe concluir que el control está bien



10 · Técnicas empleadas y por qué · Nicolás · ≈ 35 s

Nicolás: Gracias, Sergio. Cada técnica responde a una pregunta. Registramos las decisiones antes de implementarlas, para que código y documento no se contradigan. Probamos cada capacidad del laboratorio antes de construir sobre ella. Las pruebas unitarias cubren las reglas, las de extremo a extremo cada requisito, y la verificación posterior confirma que lo desplegado existe y responde. Y la más importante: una auditoría independiente, porque quien despliega no debería ser quien concluya que su control funciona.

INDICACIÓN La auditoría es un programa externo, Cotejo, no una prueba más del equipo.

BLOQUE 4

Riesgos y controles

- 11 Activos identificados
- 12 Riesgos, probabilidad e impacto
- 13 Controles implementados
- 14 Controles faltantes
- 15 Roles y permisos
- 16 Matriz de permisos · envíos y operación
- 17 Matriz de permisos · administración y auditoría
- 18 Reglas de los roles que no se pueden configurar



Rastro

Bloque 4

Bloque 4 · Riesgos y controles

Portadilla: se pasa sin detenerse.

Activos identificados

Activo	Por qué importa
Datos de envíos y destinatarios	Información personal de terceros
Evidencias de entrega	Prueba de la cadena de custodia
Bitácora de auditoría	Sostiene el no repudio del sistema
Llave de cifrado	Compromete todas las evidencias
Secreto de firma de sesiones	Permite suplantar cualquier rol

Decisión de privacidad: el sistema se pobló **solo con datos sintéticos**.
Ningún dato personal real entró al sistema.



11 · Activos identificados · Nicolás · ≈ 30 s

Nicolás: Pasamos a riesgos. Identificamos cinco activos: los datos de envíos y destinatarios, que son información personal de terceros; las evidencias de entrega, que prueban la cadena de custodia; la bitácora, que sostiene el no repudio; y la llave de cifrado y el secreto de firma de sesiones, porque comprometer cualquiera de los dos compromete todo lo demás. Una decisión de privacidad: el sistema solo tiene datos sintéticos.

SI PREGUNTAN Los datos sintéticos resuelven la Ley 1581 sin renunciar a los controles que exigiría un tratamiento real: minimización, cifrado y acceso por rol están implementados.

Riesgos, probabilidad e impacto

Riesgo	Prob.	Impacto	Estado
Consulta sin filtrar por organización	Media	Muy alto	No materializado
Exposición de secretos	Media	Muy alto	Materializado y corregido
El laboratorio bloquea un servicio previsto	Media	Alto	Materializado y resuelto
El alcance crece y no se termina	Alta	Alto	Materializado y gestionado
Se agota el presupuesto de la cuenta	Media	Alto	No materializado
Identificador literal impide migrar	Media	Alto	No materializado



12 · Riesgos, probabilidad e impacto · Nicolás · ≈ 35 s

Nicolás: Esta es la matriz de riesgos. Los dos de impacto muy alto son la consulta sin filtrar por organización y la exposición de secretos. Y tres riesgos se materializaron: la exposición de secretos, que veremos en los hallazgos; el bloqueo de un servicio, porque el laboratorio impedía invocar funciones sin autenticación y lo resolvimos con la puerta de enlace; y el crecimiento del alcance, que contuvimos con la regla de no cerrar requisitos sin prueba.

INDICACIÓN Decirlo como fortaleza: una matriz donde nada ocurre es una matriz que nadie usó.

Controles implementados

Amenaza	Control	Verificado por
Acceso a datos de otra organización	Clave de partición <code>ORG#...#ENV#...</code> y capa común única	Control C-06
Operación por rol no autorizado	Autorización por operación, con registro del intento	Control C-05
Enumeración desde la consulta pública	Identificadores aleatorios, no consecutivos	Diseño · OWASP A01
Alteración del histórico	Bitácora encadenada + condición de no existencia + registro de actividad	Control C-08
Evidencias legibles por terceros	Cifrado con llave propia, rotación y bloqueo público	Controles C-02 y C-03

El aislamiento no depende de que el programador recuerde filtrar: sin el identificador de organización, la consulta no se puede construir.



13 · Controles implementados · Nicolás · ≈ 40 s

Nicolás: Cada amenaza tiene un control, y cada control una verificación. El acceso a datos de otra empresa lo impiden la clave de partición y una capa común única; lo verifica C-06. Una operación de un rol no autorizado se rechaza y queda registrada; lo verifica C-05. Los identificadores aleatorios evitan la enumeración, y la bitácora encadenada detecta la alteración del histórico. Lo central: el aislamiento no depende de que el programador recuerde filtrar; sin el identificador de la organización, la consulta ni siquiera se puede construir.

INDICACIÓN Es la diapositiva más técnica: si hay una repregunta difícil, suele ser aquí.

SI PREGUNTAN Entre organizaciones el sistema responde 404 y no 403: un 403 confirmaría que el envío existe.

Controles faltantes

El entorno impide construirlos, y se declaran en lugar de omitirse:

Rol de ejecución por función. Las ocho comparten un rol amplio. Incumple el principio de mínimo privilegio.

Ancla de integridad fuera de la cuenta. Frente a quien administra la cuenta, la arquitectura ofrece **detección**, no prevención.



14 · Controles faltantes · Nicolás · ≈ 30 s

Nicolás: Y hay dos controles que faltan, y los declaramos. Un rol de ejecución por función: las ocho funciones comparten el rol del laboratorio, que es amplio, y eso incumple el mínimo privilegio. Y un ancla de integridad fuera de la cuenta: frente a quien administra la cuenta, la arquitectura detecta una alteración, pero no la impide. Los dos los impide el entorno, no el diseño.

SI PREGUNTAN ¿Entonces no está protegido? Ningún control de integridad impide que quien administra el sistema lo destruya; lo que evita es la alteración silenciosa, y esa sí se detecta.

Roles y permisos

Rol	Puede	No puede
Administrador	Todo: envíos, catálogos, cuentas y roles	Leer la bitácora
Coordinador	Despachar, reanudar incidencias, editar catálogos	Administrar cuentas; leer bitácora
Despachador	Crear y asignar envíos, registrar eventos	Reanudar incidencias; editar catálogos
Conductor	Ver sus envíos, marcar avance, cargar evidencia	Crear o asignar envíos
Auditor	Consultar y leer la bitácora	Cualquier operación de escritura

Ningún rol combina escritura con lectura de la bitácora, y ninguna cuenta puede sumar dos roles que juntos lo hagan. No es configurable.

Los roles se definen en datos, no en código: una empresa puede crear roles propios eligiendo de la lista de operaciones, nunca inventando operaciones nuevas.



15 · Roles y permisos · Nicolás · ≈ 35 s

Nicolás: Rastro tiene cinco roles de fábrica. El administrador puede todo, menos leer la bitácora. El coordinador despacha, reanuda incidencias y mantiene catálogos. El despachador registra y asigna envíos. El conductor trabaja solo sobre sus envíos. Y el auditor consulta y lee la bitácora, sin escribir nada. La regla central es la separación de funciones: el administrador opera y el auditor revisa lo que el administrador operó. Ninguna cuenta puede ser las dos cosas.

SI PREGUNTAN Los roles viven en datos: una empresa puede crear los suyos, pero solo eligiendo de la lista de operaciones que ya existe.

Matriz de permisos · envíos y operación

Operación	Administrador	Coordinador	Despachador	Conductor	Auditor
Registrar envíos, uno a uno o en lote	✓	✓	✓	—	—
Asignar mensajero y ver toda la operación	✓	✓	✓	—	—
Ver el listado de envíos	✓	✓	✓	Solo suyos	—
Abrir un envío y su histórico	✓	✓	✓	✓	✓
Marcar el avance del envío	✓	✓	✓	Solo suyos	—
Autorizar un envío detenido por incidencia	✓	✓	—	—	—
Adjuntar la prueba de entrega	✓	—	—	Solo suyos	—
Consultar las evidencias cargadas	✓	✓	✓	—	✓

Quien detiene no es quien reanuda: el conductor reporta la incidencia; autorizar la continuación corresponde a otro rol.



16 · Matriz de permisos · envíos y operación · Nicolás · ≈ 30 s

Nicolás: Esta matriz sale directamente del código. En la operación, los tres roles operativos registran, asignan y marcan avance; el conductor solo lista, marca avance y adjunta evidencia de los envíos que tiene asignados. Y un detalle de diseño: el conductor reporta la incidencia, pero no puede autorizar que el envío continúe; eso lo hacen el coordinador o el administrador. Quien detiene no es quien reanuda.

SI PREGUNTAN Abrir un envío por su identificador sí se puede dentro de la propia empresa; el identificador es aleatorio, así que no se puede adivinar.

Matriz de permisos · administración y auditoría

Operación	Administrador	Coordinador	Despachador	Conductor	Auditor
Ver las cuentas de la empresa	✓	✓	—	—	✓
Crear cuentas	✓	—	—	—	—
Cambiar rol, datos o estado de una cuenta	✓	—	—	—	—
Ver los roles y sus permisos	✓	—	—	—	✓
Crear roles y cambiar sus permisos	✓	—	—	—	—
Ver los mensajeros disponibles	✓	✓	✓	—	—
Ver tiendas, clientes y transportistas	✓	✓	✓	✓	✓
Modificar tiendas, clientes y transportistas	✓	✓	—	—	—
Ver el tablero de indicadores	✓	✓	✓	✓	✓
Leer la bitácora	—	—	—	—	✓
Verificar la integridad de la cadena	—	—	—	—	✓

De 19 operaciones: Administrador 17 · Coordinador 12 · Despachador 9 · Conductor 6 · Auditor 8



17 · Matriz de permisos · administración y auditoría · Nicolás · ≈ 25 s

Nicolás: En administración, solo el administrador crea cuentas, cambia roles y define permisos; el auditor puede verlos, pero no modificarlos. Las dos últimas filas son la separación de funciones: leer la bitácora y verificar su integridad son exclusivas del auditor. Por eso el administrador tiene 17 de las 19 operaciones: le faltan exactamente esas dos.

Reglas de los roles que no se pueden configurar

Regla	Qué evita
El administrador conserva siempre sus 17 operaciones y su rol no se edita	Que una edición deje a la empresa sin nadie que pueda corregirla
Ningún rol ni cuenta combina escritura con lectura de la bitácora	Que quien opera revise su propio rastro
Nadie concede un permiso que no tiene	La autopromoción: el intento queda en la bitácora como escalada de privilegios
Sin permiso de asignar, solo se actúa sobre los envíos propios	Que un mensajero marque avance o cargue evidencia en envíos ajenos

Todo intento, permitido o rechazado, queda en la bitácora.

Cada regla tiene su prueba en `tests/e2e/test_roles.py` y `tests/unit/test_autorizacion_y_claves.py`.



18 · Reglas de los roles que no se pueden configurar · Nicolás · ≈ 35 s

Nicolás: Cuatro reglas no se pueden configurar desde ninguna pantalla. El rol de administrador no se edita, para que un error no deje a la empresa sin quien lo corrija. Ningún rol ni cuenta combina operar con auditar. Nadie concede un permiso que no tiene; si lo intenta, queda en la bitácora como escalada de privilegios. Y sin permiso de asignar, solo se actúa sobre los envíos propios. Cada regla tiene su prueba automatizada. Oscar sigue con la normativa.

SI PREGUNTAN La separación se comprueba sobre la suma de roles de la cuenta: si no, un administrador podría añadirse el rol de auditor sin que ningún rol rompiera la regla por separado.

BLOQUE 5

Normativas

19 Estándares aplicados

20 Cumplimientos e incumplimientos



Rastro

Bloque 5

Bloque 5 · Normativas

Portadilla: se pasa sin detenerse.

Estándares aplicados

Marco	Qué exige	Cómo se cumple
Ley 1581 de 2012 y Decreto 1377	Tratamiento de datos personales	Minimización, cifrado, acceso por rol. Solo datos sintéticos
ISO/IEC 27001:2022 A.8.24 y A.8.13	Criptografía y copias	Llave propia con rotación; versionado
CIS AWS Benchmark	Configuración segura de la cuenta	Registro con validación de integridad; sin acceso público
OWASP Top 10:2021 A01	Control de acceso	Identificadores aleatorios; 404 y no 403 entre organizaciones
NIST SP 800-92	Registros de seguridad	La bitácora conserva actor, acción, recurso y momento
AWS Well-Architected, seguridad	Mínimo privilegio	No se cumple. Declarado como hallazgo permanente



19 · Estándares aplicados · Oscar · ≈ 35 s

Oscar: Gracias, Nicolás. Aplicamos seis marcos. La Ley 1581, con minimización, cifrado, acceso por rol y datos sintéticos. ISO 27001 en criptografía y copias. El benchmark CIS en la configuración de la cuenta. OWASP A01 en control de acceso: entre organizaciones respondemos 404 y no 403, para no revelar que un envío existe. NIST 800-92 en los registros. Y la última fila va a propósito: el mínimo privilegio que pide AWS no se cumple, y lo ponemos junto a los cumplimientos.

INDICACIÓN No leer la tabla entera: nombrar los marcos y detenerse en la última fila.

Cumplimientos e incumplimientos

Verificado por una **auditoría independiente**, ejecutada por un programa distinto contra el sistema desplegado:

11

controles

10

conformes

1

desviado

0

sin ejecutar

Incumple: un secreto permanece en el historial del repositorio, ya invalidado.

Incumple, sin posibilidad de corregir aquí: mínimo privilegio.



20 · Cumplimientos e incumplimientos · Oscar · ≈ 25 s

Oscar: Esto no lo afirmamos solo nosotros: lo verificó una auditoría independiente, un programa distinto ejecutado contra el sistema desplegado. Once controles: diez conformes, uno desviado y ninguno sin ejecutar. El desviado es un secreto que sigue en el historial del repositorio, aunque ya está invalidado. El otro incumplimiento, el mínimo privilegio, no se puede corregir en este entorno.

INDICACIÓN Presentar el desviado sin bajar la voz: es la transición a los hallazgos.

BLOQUE 6

Hallazgos y evidencias

- 21 Evidencia · Pruebas automatizadas
- 22 Evidencia · Despliegue verificado
- 23 Hallazgo · El incidente del secreto
- 24 Trazabilidad de las evidencias



Rastro

Bloque 6

Bloque 6 · Hallazgos y evidencias

Portadilla: se pasa sin detenerse.

Evidencia · Pruebas automatizadas

234

superadas

4

omitidas

0

fallos

14

segundos

Conjunto	Pruebas
Unitarias	84
Extremo a extremo	120
Programa de auditoría	34

No requieren credenciales ni contenedores. **Cualquiera puede repetirlos.**



21 · Evidencia · Pruebas automatizadas · Oscar · ≈ 25 s

Oscar: Primera evidencia: la suite de pruebas. 234 superadas, cuatro omitidas y ninguna fallida, en unos catorce segundos: 84 unitarias, 120 de extremo a extremo y 34 del programa de auditoría. No necesitan credenciales de AWS ni contenedores, así que cualquiera puede repetirlos. Si el jurado quiere, la ejecutamos ahora.

INDICACIÓN Tener una terminal abierta en la raíz del repositorio con `python -m pytest -q` listo.

SI PREGUNTAN Las cuatro omitidas requieren condiciones que no existen en la ejecución local; se cuentan aparte para no informar más cobertura de la que hubo.

Evidencia · Despliegue verificado

Seis grupos comprobados, código de salida 0, el 26/09/2026:

- tres tablas, llave de cifrado, dos contenedores
- las ocho funciones
- puerta de enlace y registro de actividad
- consulta pública a través de la interfaz: **404 esperado**
- catálogo de estados: responde

El 404 no es un error: es una **prueba negativa** que confirma la ruta completa.



22 · Evidencia · Despliegue verificado · Oscar · ≈ 35 s

Oscar: Segunda evidencia: la verificación del despliegue del 26 de septiembre, con código de salida cero. Comprueba las tres tablas, la llave, los dos contenedores, las ocho funciones, la puerta de enlace y el registro de actividad. Un detalle: la consulta pública responde 404, y eso es lo esperado. Pedimos un envío que no existe; que conteste «no existe» demuestra que la petición cruzó la puerta de enlace, llegó a la función y ejecutó su lógica.

Hallazgo · El incidente del secreto

Condición	Un secreto de firma quedó publicado en el repositorio durante 27 minutos
Criterio	ISO/IEC 27001 A.5.17 y A.8.4
Causa	La exclusión existía y se retiró en bloque al versionar las evidencias
Riesgo	Cualquiera podría firmar un token con rol de administrador
Evidencia	evidencias-despliegue/20260926T232257Z-rotacion-secreto.txt

Corrección. Rotación, redespiegue de las ocho funciones, comprobación de rechazo y exclusión. Sin indicios de explotación en la ventana.

Lo detectó el equipo al revisar el despliegue: ningún control cubría los secretos. Desde entonces lo vigila uno automatizado, C-09.



23 · Hallazgo · El incidente del secreto · Oscar · ≈ 45 s

Oscar: Este es nuestro hallazgo más serio. El secreto con que se firman las sesiones quedó publicado en el repositorio durante 27 minutos, contra lo que exige ISO 27001 sobre información de autenticación. La causa: la exclusión del archivo existía, y la retiramos en bloque al versionar las evidencias. Con ese secreto, cualquiera podía firmar un token de administrador. Lo rotamos, redespiegamos las ocho funciones y comprobamos que el secreto viejo se rechaza; no hubo indicios de uso. Lo detectamos nosotros al revisar el despliegue, porque ningún control cubría los secretos; por eso hoy existe uno automatizado, C-09.

INDICACIÓN Decírla despacio: es la diapositiva más fuerte del deck.

SI PREGUNTAN ¿Cómo saben que no se usó? Durante la ventana, las seis funciones con rutas protegidas no recibieron ninguna invocación, y las otras dos solo las de nuestra propia verificación.

Trazabilidad de las evidencias

Evidencia	Origen	Fecha
Verificación del despliegue	95-verificar.sh , código de salida 0	26/09/2026
Suite de pruebas	python -m pytest -q	Reproducible
Rotación del secreto	Comparación de huellas, sin exponer valores	26/09/2026
Auditoría de controles	Ejecución ...235724886Z-4f87a8	26/09/2026

Cada una con comando, salida completa y fecha, en el repositorio.



24 · Trazabilidad de las evidencias · Oscar · ≈ 25 s

Oscar: Cada evidencia que mostramos tiene origen y fecha, y está en el repositorio con su comando y su salida completa: la verificación del despliegue, la suite de pruebas, que cualquiera puede repetir, la rotación del secreto, comparada por huellas sin exponer ningún valor, y la ejecución de la auditoría del 26 de septiembre.

INDICACIÓN Responde a lo que pide la rúbrica: contexto, fecha y origen de cada evidencia.

BLOQUE 7

Conclusiones y mejoras

- 25 Resultados generales
- 26 Acciones correctivas
- 27 Limitaciones declaradas
- 28 Cierre



Rastro

Bloque 7

Bloque 7 · Conclusiones y mejoras

Portadilla: se pasa sin detenerse.

Resultados generales

- Los **nueve requisitos** comprometidos se cumplen y pueden comprobarse
- **Tres verificaciones independientes** llegan a la misma conclusión: pruebas, despliegue y auditoría externa
- Tres riesgos se materializaron; los tres se gestionaron y se documentan
- El incidente del secreto se detectó a mano y dejó un control automatizado que antes no existía: C-09



Oscar: En resultados: los nueve requisitos se cumplen y se pueden comprobar. Tres verificaciones independientes llegan a la misma conclusión: las pruebas, la verificación del despliegue y la auditoría externa, y ninguna depende de nuestra palabra. Tres riesgos se materializaron y los tres se gestionaron. Y el incidente del secreto, que detectamos a mano, nos dejó un control automatizado que antes no existía.

Acciones correctivas

Acción	Responsable	Prioridad	Tiempo
Reescribir el historial del repositorio	Nicolás Torres	Alta	2 horas
Rol de ejecución por función	Sergio Montoya	Alta	1 semana · depende del entorno
Validar con una empresa real	Oscar Rincón	Alta	Un semestre
Ancla externa de la bitácora	Sergio Montoya	Media	3 semanas · depende del entorno
Concurrencia en el encadenamiento	Nicolás Torres	Media	1 semana
Derivación de contraseñas más resistente	Nicolás Torres	Baja	1 semana



26 · Acciones correctivas · Oscar · ≈ 30 s

Oscar: Estas son las acciones correctivas, cada una con responsable, prioridad y tiempo. Las de prioridad alta: reescribir el historial del repositorio, unas dos horas; un rol de ejecución por función, que depende del entorno; y validar con una empresa real, que toma un semestre. Después, el ancla externa de la bitácora, la concurrencia en el encadenamiento y una derivación de contraseñas más resistente.

SI PREGUNTAN El criterio de cierre de cada acción está en el apartado 15.2 del documento.

Limitaciones declaradas

Sin usuarios reales. Demostramos que el sistema funciona, no que resuelva el problema en operación.

Mínimo privilegio incumplido. El entorno no permite crear roles.

Integridad: detección, no prevención. Frente a quien administra la cuenta, la arquitectura detecta la alteración pero no la impide.



Oscar: Y tres limitaciones que no vamos a suavizar. No tuvimos usuarios reales: demostramos que el sistema funciona, no que resuelva el problema en operación. El mínimo privilegio no se cumple, porque el entorno no permite crear roles. Y frente a quien administra la cuenta, la integridad ofrece detección, no prevención. Sergio cierra.

Cierre

Las restricciones del entorno no fueron un obstáculo: fueron el insumo de diseño.

- Sin cómputo persistente → arquitectura bajo demanda
- Entorno volátil → despliegue reproducible
- Sin roles propios → la limitación más importante, declarada y no disimulada

Ningún requisito se cerró sin su prueba.

`github.com/Serann10255/Rastro`



28 · Cierre · Sergio · ≈ 25 s

Sergio: Cierro con esto: las restricciones del entorno no fueron un obstáculo, fueron el insumo del diseño. Sin cómputo persistente, la arquitectura es bajo demanda; con un entorno volátil, el despliegue es reproducible; y sin roles propios, la limitación quedó declarada, no disimulada. Ningún requisito se cerró sin su prueba. Muchas gracias; quedamos atentos a sus preguntas.

INDICACIÓN Después de «gracias», callarse. No resumir otra vez.